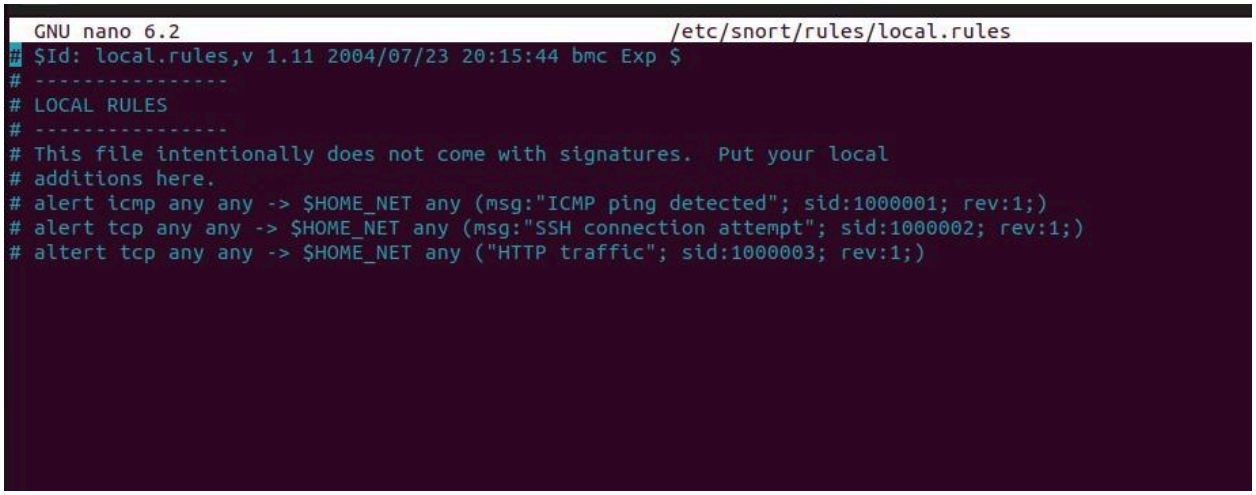
Finding 6 - Detect Nmap SYN Scan and Map to MITRE ATT&CK T1046

Objective

Write a Snort rule that detects an Nmap SYN scan and map it to **MITRE ATT&CK T1046 - Network Service Discovery** (previously named "Network Service Scanning").

Rule added to /etc/snort/rules/local.rules

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"MITRE T1046 - Nmap SYN Port Scan Detected"; flags:S; threshold:type threshold, track by_src, count 20, seconds 1; classtype:attempted-recon; metadata:mitre_technique T1046; reference:url,attack.mitre.org/techniques/T1046/; sid:1000004; rev:1;)
```



Rule explanation

Option	Purpose
`alert tcp $EXTERNAL_NET any -> $HOME_NET any`	Traffic from outside networks to any port on the protected network
`msg:"MITRE T1046 - ..."`	Alert text with the technique ID
`flags:S`	Matches TCP packets with only the SYN flag set (half-open scan signature)
`threshold:type threshold, track by_src, count 20, seconds 1`	Alerts when 20 SYN packets from the same source occur within 1 second
`classtype:attempted-recon`	Classifies the alert as reconnaissance
`metadata:mitre_technique T1046`	Machine-readable MITRE tag

Option	Purpose
`reference:url,attack.mitre.org/techniques/T1046/`	Link to the official ATT&CK page
`sid:1000004; rev:1;`	Unique ID and revision

Test procedure

1. Validate the configuration on the Ubuntu VM:

```
sudo snort -T -i <interface> -c /etc/snort/snort.conf
```

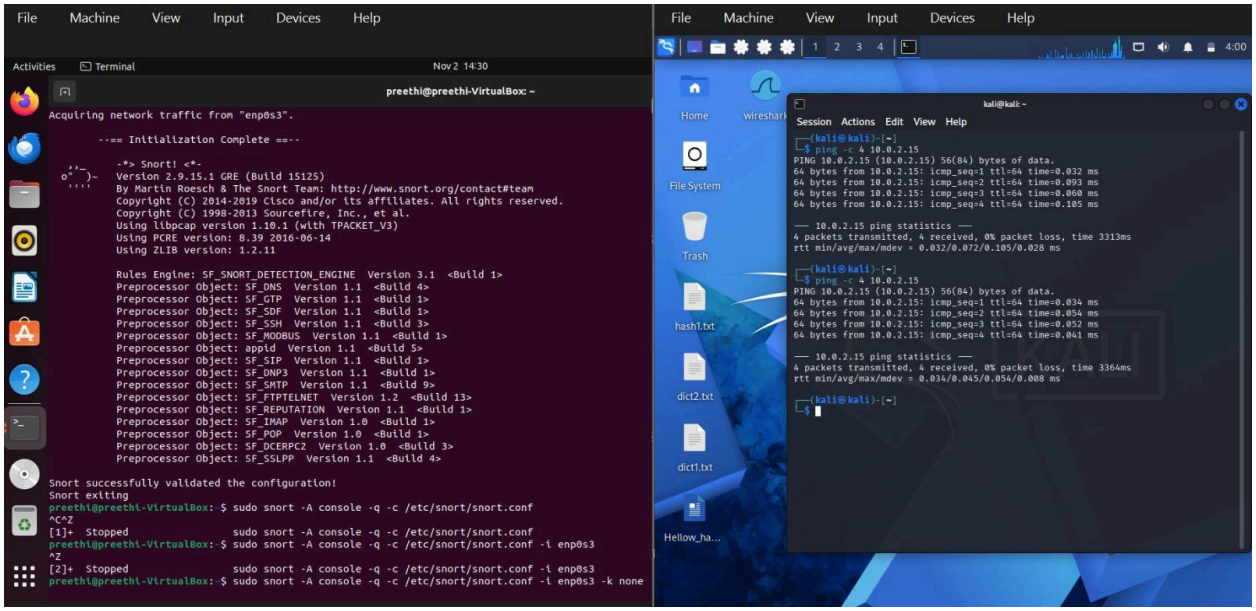
2. Start Snort:

```
sudo snort -A console -q -c /etc/snort/snort.conf -i <interface>
```

3. From Kali, run the scan:

```
nmap -sS <ubuntu-vm-ip>
```

4. Check Snort alerts:



Expected alert format:

```
[**] [1:1000004:1] MITRE T1046 - Nmap SYN Port Scan Detected [**]
[Classification: Attempted Information Leak] [Priority: 2]
TCP <kali-ip>:<port> -> <ubuntu-ip>:<port>
```

MITRE ATT&CK mapping

Item	Detail
Tactic	Discovery
Technique	T1046 - Network Service Discovery
Tool used	Nmap (`-sS` SYN scan)

Item	Detail
Evidence	Many SYN-only packets from one source in a short time
Detection	Snort SID 1000004

Analysis

- Nmap's default privileged scan (`-sS`) sends a SYN to each port without completing the handshake. A normal client sends few SYNs, so 20 or more in one second from one source is a reliable scan indicator.
- The `threshold` prevents an alert for every packet; it triggers on the pattern.
- Including the technique in `msg`, `metadata` and `reference` makes the alert easy to map in a SIEM dashboard.

SOC response ideas

Action	Reason
Check the source IP (internal or external, known or unknown)	Decide if it is an authorised scanner
Review firewall and Sysmon Event ID 3 logs for follow-up connections	See whether the scanner reached open services
Block the source if unauthorised	Stop further reconnaissance
Escalate if followed by exploitation or login attempts	Possible active attack

Optional extension - SSH brute force rule (T1110)

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 22 (msg:"MITRE T1110 - SSH Brute
Force Attempt Detected"; flow:to_server; flags:S; threshold:type threshold,
track by_src, count 5, seconds 60; classtype:attempted-admin;
metadata:mitre_technique T1110;
reference:url,attack.mitre.org/techniques/T1110/; sid:1000005; rev:1;)
```

This rule alerts when one source starts 5 or more new SSH connections within 60 seconds, a common brute-force pattern (T1110 Brute Force).